



Dompé

DOCUMENTAZIONE TECNICA

Runbook operativo

Prerequisiti di piattaforma, deploy, configurazione, manutenzione, diagnosi e rollback



Campo	Valore
Applicativo	Guest Portal — Cisco Catalyst 9800 Guest Management Desk
Indirizzo (produzione)	https://guestportal.dompe.com
Documento	OPS — Runbook operativo
Versione	1.0
Data di emissione	25 settembre 2026
Stato	Emesso
Destinatari	IT Infrastructure, Cloud Operations, Service Desk
Classificazione	Uso interno
Repository di riferimento	github.com/ACF-Dompe/Centralino
Revisione del codice	main · f427890

Indice

1	Scopo e ambito	3
1.1	Ambienti e nomenclatura	3
2	Prerequisiti di piattaforma	4
3	Configurazione di Entra ID	5
3.1	Applicazione SAML	5
3.2	Applicazione per la posta	5
4	Segreti in Key Vault.....	6
4.1	Collegamento dei segreti alla Container App.....	6
5	Deploy	7
5.1	Tramite pipeline	7
5.2	Manualmente	7
5.3	Dati di riferimento — passo obbligatorio alla prima installazione	8
5.4	Verifica post-deploy	8
6	Primo accesso amministrativo	9
7	Gestione degli account di emergenza.....	10
7.1	Attivazione	10
7.2	Che cosa si può fare dal pannello	10
8	Gestione corrente.....	11
8.1	Aggiungere una sede	11
8.2	Abilitare un operatore	11
8.3	Sospendere o rimuovere	11
9	Sorveglianza.....	12
9.1	Che cosa guardare	12
9.2	Alert obbligatorio sugli accessi di emergenza	12
10	Diagnosi.....	13
11	Rollback.....	14
12	Manutenzione ricorrente	15
13	Checklist go-live	16

1 Scopo e ambito

Questo documento raccoglie ciò che serve per installare, aggiornare, sorvegliare e riparare il Guest Portal. Presuppone che le risorse di piattaforma esistano: l'applicazione le **consuma**, non le crea.

Modello consume-only

Resource Group, ambiente Container Apps, le due Container App, le identità gestite, Key Vault, PostgreSQL, Container Registry, Application Gateway e il job di migrazione sono pre-provisionati dal team di piattaforma. La pipeline esegue **soltanto aggiornamenti**. `scripts/provision.sh <ambiente>` effettua una verifica in sola lettura della presenza delle risorse attese.

1.1 Ambienti e nomenclatura

Ambiente	Suffisso	Hostname	Origine del deploy
Sviluppo	dev	<code>https://guestportal-dev.dompe.com</code>	Avvio manuale del workflow
Collaudo	stg	<code>https://guestportal-stg.dompe.com</code>	Push sul ramo <code>staging</code>
Produzione	prod	<code>https://guestportal.dompe.com</code>	Push sul ramo <code>main</code>

Tabella 1 — Ambienti. La produzione, per convenzione della zona aziendale, non ha suffisso nell'hostname.

Nel seguito `<hostname>` sta per l'hostname dell'ambiente su cui si sta lavorando: in produzione è `guestportal.dompe.com`.

Risorsa	Convenzione
Container App backend	<code>ca-guestportal-backend-<amb></code>
Container App frontend	<code>ca-guestportal-frontend-<amb></code>
Identità gestita backend	<code>uami-guestportal-backend-<amb></code> — AcrPull + Key Vault Secrets User + principal su PostgreSQL
Identità gestita frontend	<code>uami-guestportal-frontend-<amb></code> — solo AcrPull
Job di migrazione	<code>job-guestportal-migrate-<amb></code>
Database	<code>guestportal_<amb></code>
Immagini	<code>guestportal-backend · guestportal-frontend</code> , tag <code><sha></code> e alias <code><amb></code>

Tabella 2 — Convenzioni di denominazione.

Le identità gestite sono **due**, una per Container App, per rispettare il principio del minimo privilegio: il frontend non legge segreti e non deve poterlo fare.

2 Prerequisiti di piattaforma

1. Resource Group, ambiente Container Apps **internal**, Key Vault, Container Registry, PostgreSQL Flexible Server, Application Gateway.
2. Le due identità gestite con i ruoli indicati sopra.
3. Il database e il principal Entra mappato sull'identità del backend (`pgaadauth_create_principal`) con le relative concessioni. **È un passo manuale, non automatizzabile dal codice.**
4. Le due Container App e il job di migrazione, creati con `--ingress external`.
5. Egress dalla subnet Container Apps verso la rete di gestione dei controller.
6. Voce DNS dell'hostname verso l'indirizzo privato dell'Application Gateway.

Ingress: usare `external`

In Container Apps `external` significa «esterno all'ambiente», non «esposto su Internet». Su un ambiente `internal`, un'app `external` è raggiungibile da tutta la rete virtuale — quindi dall'Application Gateway, che sta fuori dall'ambiente. Un'app `internal` è raggiungibile solo dalle altre app dello stesso ambiente e risponde **404 «Azure Container App - Unavailable»** a ogni richiesta da rete virtuale o gateway. Conseguenza pratica: con `external` il nome di dominio **non contiene** il segmento `.internal.`, e i pool dell'Application Gateway devono usare quel nome.

3 Configurazione di Entra ID

3.1 Applicazione SAML

1. Registrare l'applicazione (account del solo tenant).
2. Aggiungere una piattaforma Web con URI di reindirizzamento `https://<hostname>/api/auth/callback`.
3. Scaricare i metadati di federazione e ricavarne l'endpoint SSO e il certificato in formato PEM.
4. Impostare l'Entity ID (`https://<hostname>/saml`), che deve coincidere con `SAML_ISSUER`.
5. Impostare l'URL di disconnessione front-channel: `https://<hostname>/api/auth/slo/callback`.
6. Impostare il formato del NameID su **persistent**, con origine `user.userPrincipalName`.
7. **Signing Option** = «Sign SAML response and assertion» (vedi nota).

VALORI PER LA PRODUZIONE

Redirect URI (ACS)	<code>https://guestportal.dompe.com/api/auth/callback</code>
Entity ID (Identifier)	<code>https://guestportal.dompe.com/saml</code>
Front-channel logout	<code>https://guestportal.dompe.com/api/auth/slo/callback</code>

Claim	Attributo di origine	Obbligatorio	Uso
emailaddress	<code>user.mail</code>	Sì	Visualizzazione e audit
name	<code>user.displayName</code>	Sì	Intestazione dell'interfaccia
givenname	<code>user.givenName</code>	Sì	Profilo
surname	<code>user.surname</code>	Sì	Profilo
objectidentifier	<code>user.objectId</code>	Consigliato	Chiave stabile della directory applicativa
upn	<code>user.userPrincipalName</code>	Sì	Identificazione e convenzione amministratori
nameID	<code>user.userPrincipalName</code>	Sì	Soggetto SAML

Tabella 3 — Mappatura delle claim.

Signing Option

L'impostazione predefinita di Entra («Sign SAML assertion») firma solo l'asserzione, mentre l'applicazione pretende anche la firma della risposta: ogni accesso fallisce con «Invalid document signature». Il rimedio preferito è lato IdP, perché mantiene la copertura della firma sull'intero documento. Dove quell'impostazione non è modificabile, si abbassa il requisito con `SAML_WANT_AUTHN_RESPONSE_SIGNED=false`: le claim restano protette, perché la firma dell'asserzione resta incondizionata.

3.2 Applicazione per la posta

Una registrazione applicativa separata con permesso **applicativo** `Mail.Send`, consenso amministratore concesso, e una casella licenziata come mittente. Servono `MAIL_GRAPH_TENANT_ID`, `MAIL_GRAPH_CLIENT_ID`, `MAIL_GRAPH_CLIENT_SECRET` (da Key Vault), `MAIL_GRAPH_USER_ID` e `MAIL_GRAPH_FROM_ADDRESS`.

4 Segreti in Key Vault

Variabile d'ambiente	Segreto	Obbligatorio
DATABASE_URL	DATABASE-URL	Sì — senza password: l'autenticazione è a token Entra
SESSION_SECRET	SESSION-SECRET	Sì — almeno 64 caratteri casuali
SAML_ENTRY_POINT	SAML-ENTRY-POINT	Sì
SAML_ISSUER	SAML-ISSUER	Sì
SAML_CALLBACK_URL	SAML-CALLBACK-URL	Sì
SAML_CERT	SAML-CERT	Sì — PEM, comprese le righe di delimitazione
WLC_PASSWORD_<CODICE>	WLC-PASSWORD-<CODICE>	Sì — una per sede
SAML_DECRYPTION_KEY	SAML-DECRYPTION-KEY	Solo con asserzioni cifrate
SAML_LOGOUT_URL · SAML_LOGOUT_CALLBACK_URL	SAML-LOGOUT-URL · SAML-LOGOUT-CALLBACK-URL	Solo con Single Logout
MAIL_GRAPH_CLIENT_SECRET	MAIL-GRAPH-CLIENT-SECRET	Solo con la posta attiva
APPLICATIONINSIGHTS_CONNECTION_STRING	APPINSIGHTS-CONNECTION-STRING	Solo con Application Insights
BREAKGLASS_SEED_PASSWORD	BREAKGLASS-SEED-PASSWORD	Solo al bootstrap — legare al solo job di migrazione

Tabella 4 — Segreti richiesti per ambiente.

```
az keyvault secret set --vault-name <KV> --name SESSION-SECRET --value "<64+ caratteri casuali>"
az keyvault secret set --vault-name <KV> --name SAML-CERT --file ./saml-cert.pem
az keyvault secret set --vault-name <KV> --name WLC-PASSWORD-MIL --value "<password admin del controller>"
```

4.1 Collegamento dei segreti alla Container App

Container Apps non capisce la sintassi di App Service

La forma `@Microsoft.KeyVault(SecretUri=...)` **non viene espansa** da Container Apps: al container arriva il testo letterale. È un difetto già osservato in produzione, con due conseguenze — ogni accesso SSO falliva con «idpCert is not in PEM format» e `SESSION_SECRET` conteneva la stringa del riferimento, quindi una chiave di firma dei cookie ricavabile da informazioni pubbliche. La forma corretta usa i segreti della Container App.

```
# 1) definire il segreto dell'app come riferimento a Key Vault
az containerapp secret set -n <APP> -g <RG> \
  --secrets session-secret=keyvaultref:https://<KV>.vault.azure.net/secrets/SESSION-SECRET,identityref:<UAMI_RESOURCE_ID>

# 2) collegare la variabile d'ambiente al segreto
az containerapp update -n <APP> -g <RG> \
  --set-env-vars SESSION_SECRET=secretref:session-secret

# 3) verificare che il segreto risulti presente
az containerapp secret list -n <APP> -g <RG> -o table
```

L'applicazione valida il certificato SAML all'avvio: un riferimento non risolto viene **rifiutato con un messaggio esplicito**, l'SSO viene disabilitato e il processo resta in piedi, così l'accesso di emergenza rimane disponibile.

5 Deploy

• Pipeline CI/CD — 4 stadi, modello consume-only

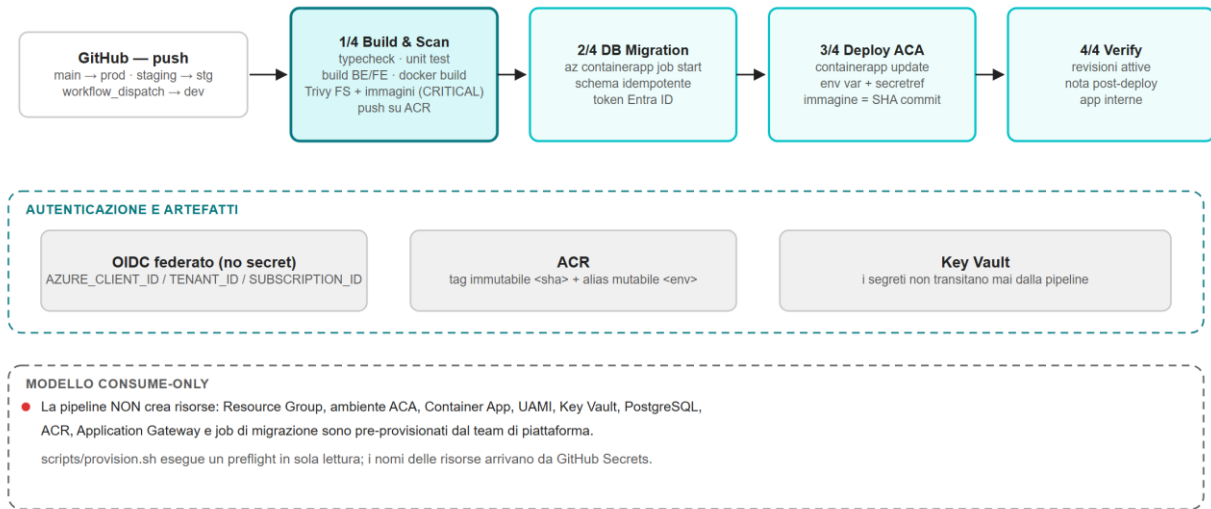


Figura 1 — Pipeline in quattro stadi e artefatti coinvolti.

5.1 Tramite pipeline

- 1. Build & Scan** — controllo dei tipi, test unitari, compilazione, costruzione delle due immagini, scansione Trivy (filesystem e immagini, blocco sulle CRITICAL), push su Container Registry con tag pari allo SHA del commit.
- 2. DB Migration** — avvio del job di migrazione pre-provisionato.
- 3. Deploy** — `az containerapp update` con la nuova immagine e le variabili d'ambiente, in un unico comando idempotente.
- 4. Verify** — nota informativa post-deploy; le applicazioni sono interne e non verificabili dall'esterno.

L'autenticazione verso Azure è a **identità federata OIDC**: nessun segreto di accesso al cloud è custodito nella pipeline. I nomi delle risorse arrivano da GitHub Secrets, così nulla è codificato nel repository.

5.2 Manualmente

```
# build e push
az acr login -n <ACR>
docker build -t <ACR>.azurecr.io/guestportal-backend:<sha> -f Dockerfile .
docker build -t <ACR>.azurecr.io/guestportal-frontend:<sha> -f Dockerfile.frontend .
docker push <ACR>.azurecr.io/guestportal-backend:<sha>
docker push <ACR>.azurecr.io/guestportal-frontend:<sha>

# migrazione, PRIMA di mettere in servizio la nuova immagine
az containerapp job start -n <MIGRATION_JOB> -g <RG>

# deploy
az containerapp update -n ca-guestportal-backend-<amb> -g <RG> --image
<ACR>.azurecr.io/guestportal-backend:<sha>
az containerapp update -n ca-guestportal-frontend-<amb> -g <RG> --image
<ACR>.azurecr.io/guestportal-frontend:<sha>
```

5.3 Dati di riferimento — passo obbligatorio alla prima installazione

Senza questo passo l'applicazione è inutilizzabile

La migrazione crea le tabelle **vuote**. Le cinque sedi sono dati anagrafici e **non esiste una API per crearle**: senza il seed, la prima schermata dopo l'accesso SSO mostra «Nessuna sede configurata» e non c'è via d'uscita dall'interfaccia.

```
az containerapp exec -n <BACKEND_APP> -g <RG> \
  --command "node backend/dist/db/seed.js"

# output atteso: Reference data seeded successfully
```

È idempotente: le sedi sono cercate per codice, quindi rieseguirlo non duplica nulla e non sovrascrive ciò che un amministratore ha corretto dal pannello.

Non usare `SEED_ENABLED=true` per farlo

Funziona, ma richiede due revisioni e, se resta attivo, il seed gira a ogni riavvio. In produzione `SEED_ENABLED` resta `false`.

5.4 Verifica post-deploy

```
# da una macchina nella rete virtuale
curl -sS https://<FQDN_BACKEND>/api/healthz # 200
curl -sS https://<FQDN_BACKEND>/api/readyz # 200 + db: connected
curl -sS https://<FQDN_FRONTEND>/healthz # 200

# attraverso l'Application Gateway
curl -sS https://<hostname>/api/healthz

# verifica che l'AuthnRequest non vincoli il metodo di autenticazione
# aprire /api/auth/login, prendere SAMLRequest dal redirect,
# URL-decode → base64-decode → inflate: nessun RequestedAuthnContext
```

1. Accesso SSO completato con un utente reale.
2. Comparsa delle cinque sedi nel selettore.
3. Connessione a una sede riuscita.
4. Registrazione di un ospite di prova, con verifica della comparsa sul controller e della ricezione del messaggio.
5. Revoca dell'ospite di prova.

6 Primo accesso amministrativo

Ogni utente SSO nasce bloccato, quindi su un ambiente nuovo occorre un modo per profilare i primi amministratori. Ci sono tre vie, in ordine di preferenza.

Via	Come	Quando usarla
Convenzione sull'indirizzo	Accedere con un account <code>admin365-*</code> @dompe.onmicrosoft.com: il ruolo è concesso automaticamente.	La più semplice, se l'account esiste nel tenant.
Riga di comando	<code>appusers grant <indirizzo> --role admin --sedi MIL,AQ</code> eseguito nel container.	Non espone nulla in rete: richiede solo accesso shell. È la via consigliata.
Account di emergenza	Creato dal bootstrap della migrazione o dalla riga di comando; accedere e profilare dal pannello.	Solo se le prime due non sono praticabili; richiede di esporre l'endpoint di emergenza.

Tabella 5 — Vie per il primo accesso amministrativo.

```
az containerapp exec -n <BACKEND_APP> -g <RG> \  
  --command "node backend/dist/scripts/appusers.js list --status pending"  
  
az containerapp exec -n <BACKEND_APP> -g <RG> \  
  --command "node backend/dist/scripts/appusers.js grant m.rossi@dompe.com --role admin --sedi  
MIL,AQ"
```

7 Gestione degli account di emergenza

Disattivati per impostazione predefinita. Attivarli è una decisione consapevole: l'accesso aggira Conditional Access e MFA e non ha un secondo fattore (deviazione D1 nel documento SEC).

7.1 Attivazione

1. **Prima** popolare `BREAKGLASS_IP_ALLOWLIST` con gli intervalli di uscita aziendali e VPN. In assenza di secondo fattore è il controllo compensativo più efficace.
2. Impostare `BREAKGLASS_ENABLED=true`.
3. Creare l'account dalla riga di comando e archiviare la password nel gestore di password aziendale.
4. Configurare l'alert su Log Analytics (§9.2). **È un requisito, non una raccomandazione.**
5. Verificare: comparsa del collegamento, accesso riuscito, banner visibile, blocco funzionante.

```
make breakglass ARGS="list"
make breakglass ARGS='set bg.operator --display "Break Glass" --expires 2027-12-31'
make breakglass ARGS="unlock bg.operator"
make breakglass ARGS="disable bg.operator"

# in produzione, dentro il container:
az containerapp exec -n <BACKEND_APP> -g <RG> \
  --command "node backend/dist/scripts/breakglass.js list"
```

Dopo il bootstrap, ruotare la password

`BREAKGLASS_SEED_PASSWORD` va legata **solo** al job di migrazione, mai al container backend — che non ne ha bisogno, dato che in produzione le migrazioni non girano all'avvio. Dopo il bootstrap la password va ruotata dalla riga di comando: da quel momento il valore in Key Vault non è più quello attivo.

7.2 Che cosa si può fare dal pannello

Elencare, abilitare, disabilitare, sbloccare. **Non** creare, **non** ruotare la password: quelle operazioni restano alla riga di comando, perché una sessione amministrativa compromessa non deve poter coniare una credenziale che aggira Entra ID.

8 Gestione corrente

8.1 Aggiungere una sede

1. Chiedere al team di piattaforma la creazione del segreto `WLC-PASSWORD-<CODICE>` e il collegamento alla variabile `WLC_PASSWORD-<CODICE>` della Container App backend.
2. Creare la sede dal pannello. Nasce **fuori servizio**, con il codice che diventa immutabile.
3. Compilare indirizzo del controller, porte, account e SSID.
4. Eseguire la prova di connessione: deve dare esito positivo.
5. Mettere la sede in servizio.
6. Concedere la sede agli operatori interessati.

Il codice di sede non è modificabile

È ciò che risolve il nome del segreto in Key Vault: cambiarlo scollegherebbe la sede dalla propria password. Due codici non possono nemmeno normalizzare sulla stessa variabile d'ambiente — la creazione viene rifiutata, perché le due sedi condividerebbero la credenziale.

8.2 Abilitare un operatore

1. L'utente accede una prima volta in SSO: la voce viene creata, bloccata.
2. Nel pannello, filtrare per stato «in attesa» e individuarlo dallo UPN.
3. Assegnare ruolo, stato attivo e le sedi.
4. L'effetto è immediato entro 15 secondi; l'utente non deve riautenticarsi.

8.3 Sospendere o rimuovere

- **Sospendere** blocca l'accesso entro 15 secondi, anche sul canale in tempo reale già aperto.
- **Rimuovere** cancella la voce e le concessioni; la voce viene ricreata, bloccata, al successivo accesso.
- La API rifiuta di sospendere o declassare **l'ultimo amministratore attivo**, e rifiuta a un amministratore di modificare il proprio ruolo o stato.

9 Sorveglianza

9.1 Che cosa guardare

Segnale	Dove	Soglia / criterio
/api/readyz	Sonde della piattaforma	503 significa database irraggiungibile.
Accesso di emergenza riuscito	Log Analytics	Ogni occorrenza va verificata. Severità 1.
Rifiuti di accesso di emergenza	Log Analytics	Più di 5 in 15 minuti. Severità 2.
Errori di sincronizzazione	Tabella <code>sync_logs</code> , codice 502	Ricorrenti sulla stessa sede: controller o percorso di rete.
Rifiuti di autorizzazione	Log Analytics, event: <code>authz-denied</code>	Un aumento improvviso indica un difetto di profilazione.
Promozioni ad amministratore	Log Analytics, event: <code>admin-user-updated</code>	Ogni passaggio a <code>admin</code> va riconosciuto.
Diagnostica delle sedi	Pannello di amministrazione	Esito e messaggio dell'ultima verifica per sede.

Tabella 6 — Segnali da sorvegliare.

9.2 Alert obbligatorio sugli accessi di emergenza

```
ContainerAppConsoleLogs_CL
| where TimeGenerated > ago(15m)
| extend d = parse_json(Log_s)
| where tostring(d.event) startswith "breakglass-"
| project TimeGenerated, event = tostring(d.event), reason = tostring(d.reason),
    username = tostring(d.username), ip = tostring(d.ip),
    userAgent = tostring(d.userAgent), correlationId = tostring(d.correlationId)
| order by TimeGenerated desc
```

Evento	Significato	Severità
<code>breakglass-login-success</code>	Un aggiramento dell'SSO è avvenuto. Da verificare sempre.	1
<code>breakglass-login-denied</code>	Tentativo rifiutato; il campo <code>reason</code> porta la causa reale.	2 oltre 5 in 15 minuti
<code>breakglass-account-locked</code>	Account bloccato per tentativi falliti ripetuti.	2
<code>breakglass-logout</code>	Sessione di emergenza terminata.	Informativo

Tabella 7 — Eventi di accesso di emergenza e severità suggerite.

I valori possibili di `reason` sono: `unknown-account`, `bad-password`, `account-locked`, `account-disabled`, `account-expired`, `ip-not-allowed`, `ip-throttled`, `missing-credentials`. All'utente il messaggio è sempre lo stesso: la causa vive solo nel log.

10 Diagnosi

Sintomo	Causa probabile e azione
<code>docker push</code> risponde 401	Sessione <code>az acr login</code> scaduta, o ruolo di push mancante.
La Container App non scarica l'immagine	All'identità gestita manca <code>AcrPull</code> sul registry, oppure l'identità del registry è configurata male.
Il riferimento a Key Vault non si risolve	Sintassi di App Service invece di quella di Container Apps (§4.1), oppure manca <code>Key Vault Secrets User</code> all'identità del backend, oppure il segreto non esiste.
<code>/api/readyz</code> risponde 503	Database irraggiungibile, oppure principal Entra e concessioni mancanti.
Autenticazione al database fallita	Il login non coincide con il nome dell'identità gestita, oppure <code>pgaauth_create_principal</code> non è stato eseguito.
<code>AADSTS75011</code>	L'AuthnRequest vincola il metodo di autenticazione. Non è un problema di configurazione Entra e non esiste un'impostazione lato applicazione aziendale per ignorarlo: verificare che <code>SAML_DISABLE_REQUESTED_AUTHN_CONTEXT</code> non sia <code>false</code> e che l'immagine includa la correzione. Verifica sul campo in §5.4.
«Invalid document signature» dopo l'accesso	Entra firma solo l'asserzione. Rimedio preferito: Signing Option = «Sign SAML response and assertion». Alternativa: <code>SAML_WANT_AUTHN_RESPONSE_SIGNED=false</code> .
«Unknown authentication strategy "saml"»	Il certificato dell'IdP non è utilizzabile e la strategia non è stata costruita. La causa precisa è nei log di avvio. Le rotte SSO rispondono 501 e l'accesso di emergenza resta disponibile.
Ciclo infinito di reindirizzamenti all'accesso	Il corpo della risposta SAML non viene interpretato: verificare che l'immagine includa il parser <code>urlencoded</code> sui callback.
«Nessuna sede configurata» dopo l'accesso	La tabella delle sedi è vuota: eseguire il seed (§5.3).
Il collegamento «Accesso di emergenza» non compare	Funzione disattivata, oppure indirizzo del client fuori dalla lista consentita. L'endpoint risponde 404 in entrambi i casi, di proposito.
Accesso di emergenza sempre rifiutato	Account inesistente, disabilitato, scaduto o bloccato: il messaggio è identico in tutti i casi. La causa è nel campo <code>reason</code> del log. Sbloccare con <code>breakglass unlock <utente></code> .
Accesso di emergenza non funziona con il database giù	Atteso: gli account risiedono su PostgreSQL. Copre un'indisponibilità di Entra, non del database.
404 «Azure Container App - Unavailable» su ogni percorso	App creata con <code>--ingress internal</code> . Correggere con <code>az containerapp ingress enable --type external</code> e riallineare i pool del gateway al nuovo nome, senza <code>.internal..</code> Diagnosi: l'app risponde 200 dall'interno del container e 404 dall'esterno.
502 dall'Application Gateway	Pool o sonda puntano a un nome errato, oppure la sonda di salute fallisce.
Il controller non risponde	Egress verso la rete di gestione non abilitato. Il messaggio distingue i casi: «Host irraggiungibile» è rete, «Connessione rifiutata» è porta chiusa, «Nome host non risolto» è DNS.
«Certificato TLS del WLC rifiutato»	Il controller risponde : a fallire è la verifica del certificato, non la rete. Il Catalyst 9800 presenta un certificato autofirmato. Impostare <code>WLC_TLS_REJECT_UNAUTHORIZED=false</code> (deviazione D3) oppure installare un certificato attendibile.
Messaggi non inviati	Posta non abilitata, oppure permesso, consenso o segreto mancanti.
<code>503 authz_unavailable</code>	La risoluzione dei permessi è fallita: verificare il database. È un rifiuto voluto, non un ruolo assunto per difetto.

Tabella 8 — Sintomi, cause probabili e azioni.

11 Rollback

```
az containerapp update -n ca-guestportal-backend-<amb> -g <RG> \
--image <ACR>.azurecr.io/guestportal-backend:<sha-precedente>
az containerapp update -n ca-guestportal-frontend-<amb> -g <RG> \
--image <ACR>.azurecr.io/guestportal-frontend:<sha-precedente>
```

Le migrazioni sono **idempotenti e additive**: il rollback dell'immagine non richiede un rollback dello schema. Il tag immutabile pari allo SHA del commit rende la versione precedente sempre identificabile.

Il limite di questa garanzia

Vale finché le migrazioni restano additive. Una migrazione che rimuovesse o rinominasse una colonna romperebbe la revisione precedente e renderebbe il rollback dell'immagine insufficiente. È la ragione per cui nello schema non ci sono **DROP**.

12 Manutenzione ricorrente

Attività	Cadenza	Note
Rotazione di <code>SESSION_SECRET</code>	Annuale, o a incidente	La rotazione invalida tutte le sessioni: gli utenti devono riautenticarsi. Aggiornare il segreto e riavviare la revisione.
Rinnovo del certificato SAML	Alla scadenza indicata da Entra	Aggiornare <code>SAML-CERT</code> prima della scadenza; un certificato scaduto blocca ogni accesso SSO.
Rotazione delle password dei controller	Secondo la politica di rete	Aggiornare il segreto della sede e riavviare la revisione; non serve toccare il database.
Rotazione del segreto Graph	Alla scadenza del segreto applicativo	Un segreto scaduto ferma solo l'invio dei messaggi, non il resto.
Rotazione della password di emergenza	Semestrale, e dopo ogni uso	Da riga di comando. Archiviare nel gestore di password.
Revisione dei profili utente	Trimestrale	Verificare ruoli, stati e concessioni; rimuovere chi non opera più.
Revisione degli account di emergenza	Trimestrale	Verificare esistenza, scadenza e stato di abilitazione.
Aggiornamento delle immagini di base	Mensile, o a vulnerabilità critica	La scansione Trivy blocca sulle CRITICAL; Dependabot propone gli aggiornamenti delle dipendenze.
Pulizia dello storico	Da definire	Nessuna politica automatica. Circa 14.400 righe al giorno dalla sola sincronizzazione.

Tabella 9 — Attività di manutenzione ricorrente.

Dopo la modifica di un segreto in Key Vault occorre **riavviare la revisione** della Container App perché il nuovo valore venga letto.

13 Checklist go-live

- Applicazioni Entra create: quella SAML e quella per la posta.
- Due identità gestite create, con i ruoli assegnati.
- Segreti popolati in Key Vault e collegati con la sintassi di Container Apps.
- Database creato, principal Entra mappato all'identità del backend e concessioni assegnate.
- Immagini costruite e caricate, con tag pari allo SHA e alias di ambiente.
- Job di migrazione creato ed eseguito.
- **Sedi populate** con il seed — senza questo passo l'applicazione mostra «Nessuna sede configurata».
- Container App create con `--ingress external`.
- Nomi di dominio verificati **senza** `.internal`. e sonde di salute a 200 da una macchina nella rete virtuale, **prima** di toccare l'Application Gateway.
- Application Gateway: pool allineati ai nomi effettivi, sonde, impostazioni, listener, regole di percorso e voce DNS.
- Egress verso la rete di gestione abilitato.
- Verifica di salute, accesso SSO, connessione a una sede e invio di un messaggio.
- **Se serve l'accesso di emergenza** (opzionale, spento per default): lista di indirizzi popolata, funzione attivata, account creato da riga di comando con password archiviata, alert su Log Analytics attivo, banner e blocco verificati.